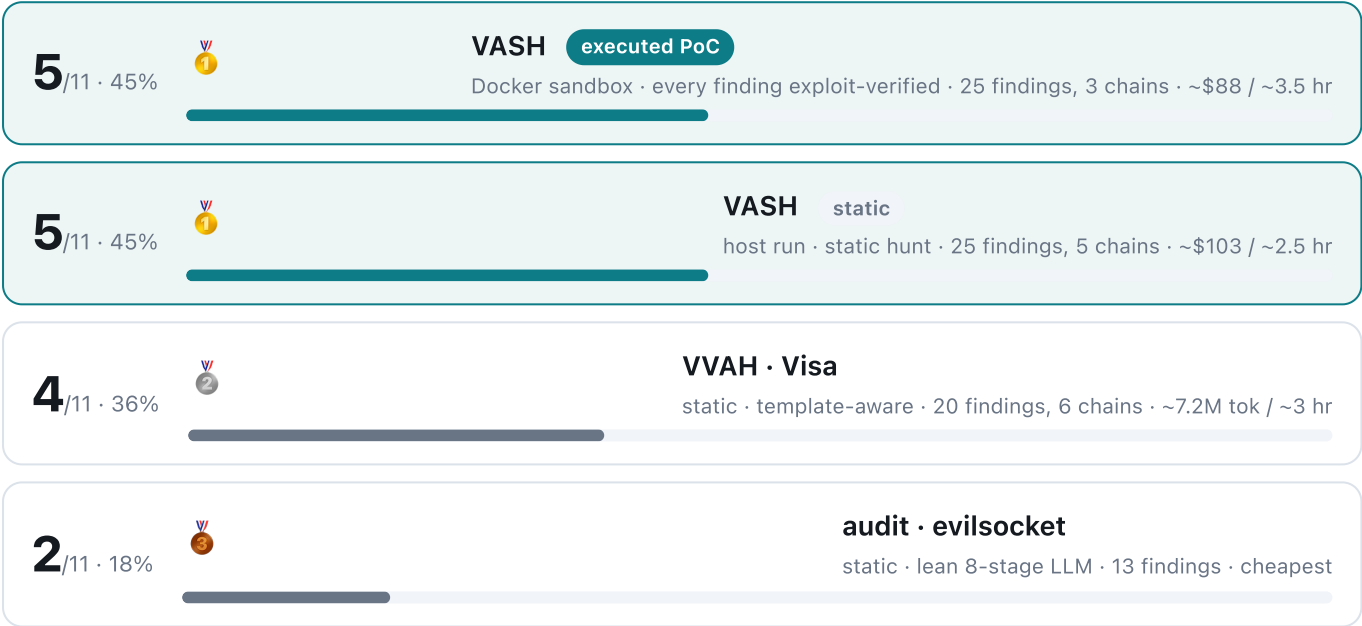


# VASH leads the field — 5 / 11, past VVAH's 4 / 11

On **datamodel-code-generator 0.55.0** (11 known CVEs), after two targeted fixes VASH out-delivers Visa's VVAH and evilsocket's audit — and is the only one of the three whose every finding is confirmed by **running a real exploit**, not static reasoning.

 **dmcg 0.55.0**    11 in-version CVEs    deterministic scorer    2026-07-25

## SCORECARD — DELIVERED RECALL



Ranked on **delivered output** — each tool's final report after its own dedup. Reference: ai-proofscan baseline 6/11; VASH's union across both runs is also 6/11 (see caveats).

## PER-CVE MATRIX

| CVE-2026-...                                 | CLASS     | AUDIT | VVAH | VASH-STATIC | VASH-POC |
|----------------------------------------------|-----------|-------|------|-------------|----------|
| <b>54621</b><br>UnionType*.jinja2 — template | codegen   | .     | ✓    | ✓           | ✓        |
| <b>54653</b><br>model/base.py · msgspec      | codegen   | .     | .    | ✓★          | .        |
| <b>54654</b><br>TypeAlias*.jinja2 — template | codegen   | .     | .    | ✓★          | ✓★       |
| <b>54655</b><br>parser/jsonschema.py         | codegen   | ✓     | ✓    | .           | ✓        |
| <b>54656</b><br>base_model.py · validator    | codegen   | .     | .    | .           | .        |
| <b>54690</b><br>http.py:29 — SSRF            | ssrf      | .     | ✓    | ✓           | ✓        |
| <b>54691</b><br>http.py · redirect / CLI     | ssrf      | .     | .    | .           | .        |
| <b>55415</b><br>imports.py                   | codegen   | .     | .    | .           | .        |
| <b>55389</b><br>parser/jsonschema.py         | traversal | ✓     | ✓    | ✓           | ✓        |
| <b>55391</b><br>http.py · redirect-bypass    | ssrf      | .     | .    | .           | .        |
| <b>55403</b><br>__main__.py · header leak    | infoleak  | .     | .    | .           | .        |
| TOTAL DELIVERED                              |           | 2     | 4    | 5           | 5        |

✓ delivered · missed ★ caught by VASH alone the two template CVEs are VASH's edge — VVAH catches one, VASH catches both

HOW VASH WENT 2 → 5

Pre-fix VASH *confirmed* 6/11 internally but delivered only 2 — a delivery bug, not a detection gap. Two fixes closed it; each step re-scored, not assumed.

2/11  
before

D8 →  
per-file  
canonical

4/11  
same findings, re-scored

D7 →  
template  
scanning

5/11  
fresh run · leads VVAH

D8 · REPORT DELIVERY

Dedup kept one canonical per group, dropping confirmed matches in other files. Fix: one canonical per (group, distinct file). Re-scoring the same 45 confirmed findings moved 2 → 4 (recovered 54690, 55415).

D7 · TEMPLATE SCANNING

The coverage sweep was hard-coded to .py only, so .jinja2 templates were never hunted. Fix: sweep by language + IaC. Coverage 50 → 70 files; both template CVEs delivered → 5.

THE DIFFERENTIATOR

## Every VASH finding is confirmed by running a real exploit

VASH hunts statically for recall, then **executes a PoC per candidate inside a Docker sandbox** and keeps only findings whose exploit actually fires. VVAH and audit are 100% static — they write PoC scripts but never run them. This is the one axis where VASH is categorically different, not just ahead on count.

**25 / 25 delivered findings · poc\_succeeded = 1**

## HONEST READING

- **5/11 per run, 6/11 union.** The hunt is stochastic — the static run uniquely caught msgspec (54653), the PoC run uniquely caught jsonschema (54655). Across both, VASH delivered 6 distinct CVEs — a real-but-unrealized single-run ceiling.
- **Executed-PoC didn't raise recall here** — both bases scored 5/11. What it buys is **confidence** (zero static-reasoning false positives), not extra corpus hits. An earlier "6–7/11" estimate was optimistic.
- **20 "extra" findings** sit outside the 11-CVE corpus; in the PoC run they're exploit-confirmed — likely real bugs beyond the catalog, or needing triage. VVAH reported 16 extras — comparable.
- **The 5 shared misses are structural:** 54691 & 55391 share 54690's exact `http.py:29` sink (scored once); 54656 is delivered but its file lacks the "validator" hint; 55415 & 55403 weren't confirmed on these draws.

## METHOD

### HELD CONSTANT

|                          |                           |
|--------------------------|---------------------------|
| Target                   | <b>dmcg 0.55.0</b>        |
| Ground truth             | <b>11 in-version CVEs</b> |
| Recon / validate / trace | <b>Opus 4.8</b>           |
| Hunt / dedup / report    | <b>Sonnet 5</b>           |
| Scorer                   | <b>score_corpus</b>       |
| Hints given              | <b>none</b>               |

### SCORING RULE

A finding matches a CVE when its **CWE class** equals the CVE's class **and** an advisory **file-hint** is a substring of the finding's path. Greedy 1:1, in-version only. Ranked on **delivered output** after each tool's own dedup.

Reproduce – static: `vash run --repo .bench-targets/dmcg-src --run-id dmcg-outperform · executed-PoC: docker run ... vash:latest run --repo /target --run-id dmcg-docker-poc · score: bench/scorer.py::score_corpus · branch evolve/vulnhunter-imports (9 commits, review: ready to merge)`